企业信息安全意识培训课件

信息安全意识培训

2026 版 · 新员工必修 · 45 分钟

你不是安全部门的旁观者
你就是入口。

2026

依据 2025 年修正的《网络安全法》编写
修正后的规定自 2026 年 1 月 1 日起施行。

本课内容

五章 · 28 页 · 末页随堂自测

01 为什么是你
威胁形势、公开通报的内部案件，以及你在风险里的三个身份 P03

02 账号与密码
口令的现行标准、抗钓鱼多因素认证，以及一封钓鱼邮件的破绽 P08

03 数据与设备
数据分级与外发口径、移动介质、远程办公与外发前的四问 P14

04 合规红线
2026 年的条号变动、三部法律落到个人的义务、罚款与禁业 P19

05 应急与上报
发现异常后的动作序列、报给谁与多久，以及及时上报的免责条款 P24

末页 **随堂自测** · 5 道判断题，答案见讲者备注 P28

章节编号与起始页码与实际页面一一对应

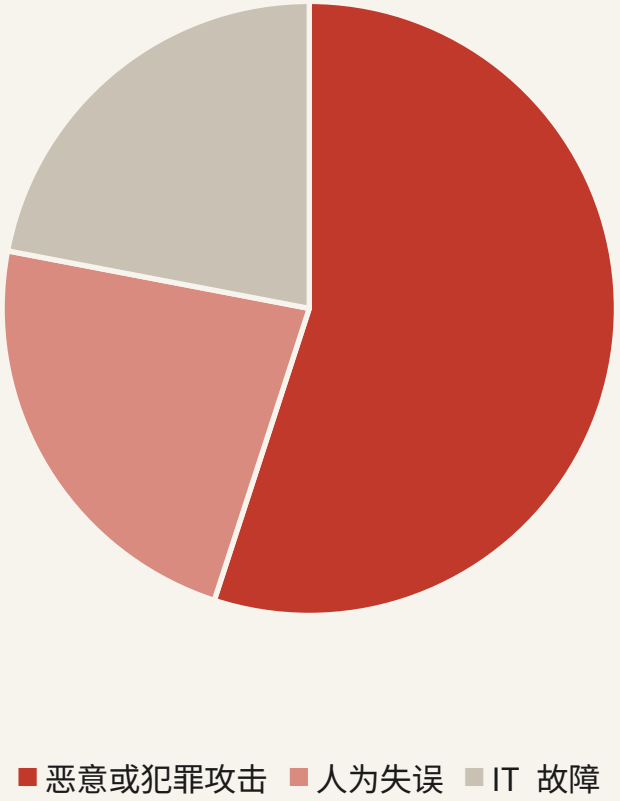
01

为什么是你

先看清楚攻击者从哪里进来

- 泄露的根因里，近一半与人直接相关
- 攻击者进门的方式，两条里有一条是社工
- 通报里的攻击者，是应聘进来的
- 你在这套风险里有三个身份

泄露的根因里，近一半与人直接相关



62%

的数据泄露中出现「人为因素」

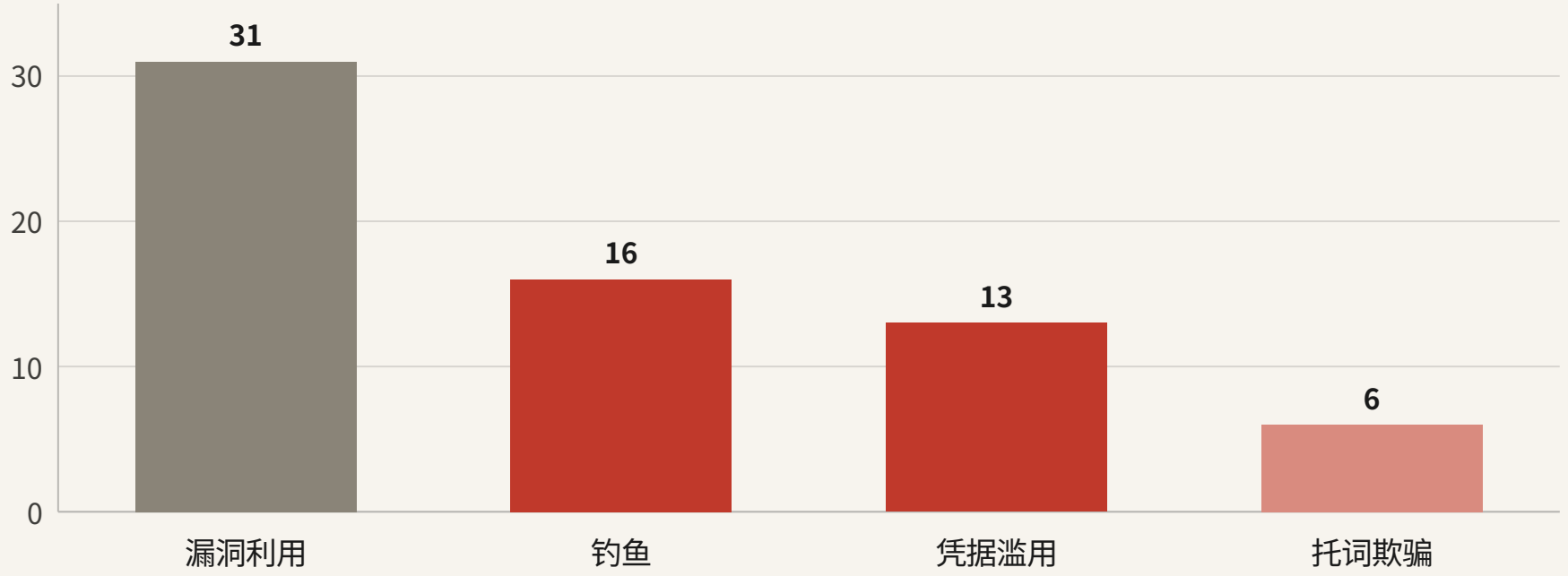
Verizon DBIR 2026，上一版为 60%

恶意攻击占**55%**，较上一年上升近 8%；
纯粹的 IT 故障只占 **22%**。

> 把「人」当成入口，比把「系统」
> 当成入口更接近事实。

来源：IBM《数据泄露成本报告》2026（F064）；Verizon DBIR 2026（F055）

攻击者进门的方式，两条里有一条是社工



漏洞由 IT 修；**钓鱼与凭据滥用，只能由你守**。

钓鱼 16% 与凭据滥用 13% 合计 29%，与漏洞利用的 31% 几乎持平；凭据滥用由上一版的第一位降至第三。

来源： Verizon DBIR 2026，数据集覆盖 2024 年 10 月至 2025 年 11 月（F056、F054）

通报里的攻击者，是应聘进来的

攻击者不一定是**黑**进来的，也可能是**应聘**进来的。

北京海淀教培木马案	制作木马程序，组织人员入职目标教培机构，定向投放木马非法控制内部计算机	抓获犯罪嫌疑人 8 名	公安部 2025 年通报
甘肃张掖快递内鬼案	勾结快递行业工作人员，利用技术手段窃取快递订单个人信息并出售牟利	抓获 18 人涉案 300 余万元	公安部 2025 年通报
四川凉山运维滥用案	利用开发运维在线学习平台的工作便利，非法获取、出售他人个人信息	抓获犯罪嫌疑人 45 名	公安部 2025 年通报
某药房内鬼盗卖案	未严格限制和监控员工数据访问权限，内部人员利用管理漏洞盗卖客户数据	内部权限失控	中国网络空间安全协会等 2025 年报告

2024 年全国公安机关侦破侵犯公民个人信息相关案件 7000 余起；
公安部 2025 年 3 月公布 10 起打击侵犯公民个人信息犯罪典型案例。

来源：公安部 2025 年 3 月通报（F043–F046）；中国网络空间安全协会等 2025 年 3 月报告（F052）

你在这套风险里有三个身份



一 · 目标

你的账号和你手里的数据，
本身就是战利品。



二 · 通道

攻击者要的是穿过你，
去拿系统里更值钱的东西。



三 · 防线

能在第一时间发现并说出
异常的，通常只有当事人。

整理　三身份为本课依据前述通报案例与统计所作的归纳，非引自单一来源。

下一章 · 账号与密码
02

本页为本章归纳，支撑事实见 P04–P06

02

账号与密码

先把最常被撬开的那把锁换掉

- 你被教了十年的口令规矩，已经过期
- 短信验证码挡不住今天的攻击者
- 一封钓鱼邮件的六处破绽
- 钓鱼早就不只在邮箱里

你被教了十年的口令规矩，已经过期

[illegible]	[illegible]	[illegible]
长度	8 位够用	单因素口令最少 15 个字符；作为多因素组成部分的最少 8 个字符
定期更换	每 90 天必须改	不得要求用户定期更换；仅在有证据表明已泄露时强制更换
组合规则	必须混合大小写数字符号	不得强制组合规则（大小写、数字、符号混合）
泄露校验	无	建立或修改口令时必须与已泄露口令黑名单完整比对，命中即拒绝并告知原因
找回方式	安全问题（宠物名字）	不得用知识型问答选择口令，不得存储可被未认证者访问的口令提示

长度优先于复杂度；不复用、不被撞库命中，比定期更换更重要。

来源： NIST SP 800-63B-4 《数字身份指南：认证与认证器管理》， 2025 年 7 月发布（ F068–F072 ）

短信验证码挡不住今天的攻击者

语音钓鱼（vishing）

冒充 IT 服务台打来电话，引导你念出验证码

MFA 推送轰炸

连续发送认证推送，直到你为了清静按下「同意」

SIM 卡交换

把你的号码转到攻击者的卡上，短信验证码直接送达

实例

拉斯维加斯 MGM、凯撒等赌场被攻破，是因为攻击者说服 IT 服务台人员重置了密码和令牌。

CISA·FBI 等七国机构联合预警 AA23-320A
2023 年首发、2025 年修订

要用抗钓鱼的多因素认证

FIDO/WebAuthn 或基于 PKI 的 MFA，不受推送轰炸和 SIM 卡交换影响。

没人有权在电话里让你**念出验证码**。

来源：CISA·FBI 等联合预警 AA23-320A，2023 年首发、2025 年 7 月修订（F051、F073）

一封钓鱼邮件的六处破绽

收件箱 · 示例（非真实邮件，仅用于教学）

1. 显示名： IT 服务台
2. 实际地址： it-serv1ce@company-mail.cn
3. **主题： 【紧急】 24 小时内未验证将停用您的账号**

尊敬的同事：系统检测到您的账号存在异常登录。
请在 24 小时内点击下方链接完成验证，否则账号将被停用。

4. 点击这里立即验证 → https://company-verify.hl.cn
5. 账号验证说明 .docx.exe （请先关闭安全提示再打开）
6. 本邮件由系统自动发送

六处破绽

1. 显示名与真实地址不一致
2. 发件域名字母重复或错拼
3. 制造时限压力的主题
4. 链接文字与实际指向不符
5. 要求先关掉安全提示的附件
6. 页脚缺少可核对的组织信息

看不准就不点；转给安全负责人，比自己验证安全。

整理 六处破绽依据 CNCERT 与 CISA 公开提示归纳

来源： CNCERT 2026 年 5 月风险提示（F074、F050）； CISA·FBI 预警 AA23-320A （F051）

钓鱼早就不只在邮箱里

语音与短信

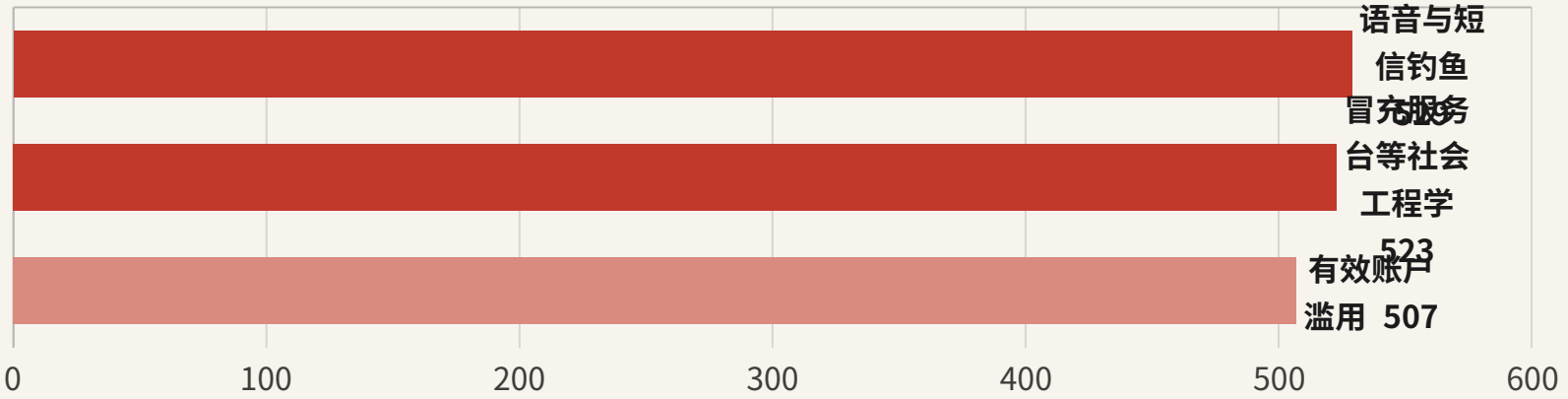
钓鱼演练中，语音和短信等移动端渠道的成功点击率中位数，比电子邮件渠道高 40%。

搜索结果

黑产通过 bing 搜索 SEO 投递高仿真钓鱼站点，并检测 refer 头规避分析——搜出来的下载站也是入口。

仿冒办公软件

2026 年 2 月至 5 月注册的 439 个钓鱼域名中，仿冒 wps、chrome 的合计 340 个，占 77.4%。



钓鱼**连续第四年**是进入被泄露组织的头号初始攻击途径；语音与短信钓鱼用于 17% 的攻击。

来源：Verizon DBIR 2026（F059）；CNCERT 2026 年 5 月风险提示（F049、F050）；IBM 2026（F063）

本章你要做的三件事

今天 把公司账号口令换成**15 个字符以上**、且没在别处用过的一串。

本周 在支持的系统上启用**抗钓鱼的多因素认证**，不再只靠短信。

长期 任何催你「立刻、马上、否则」的消息，**先停手再核实**。

电话、短信、搜索结果和邮件一视同仁。

整理 三件事为本章要点的归纳

下一章 · 数据与设备 03

依据： NIST SP 800-63B-4 （F068）； CISA·FBI 抗钓鱼 MFA 建议（F073）

03

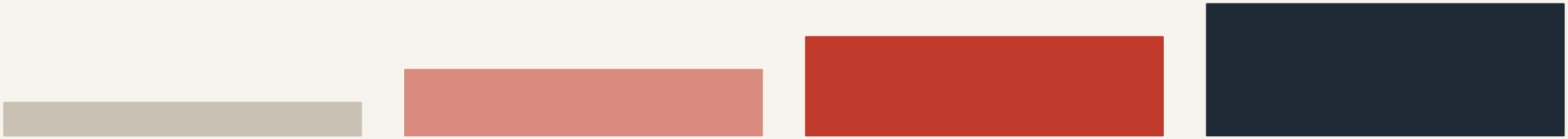
数据与设备

你手上的数据，出门之前要先过一遍

- 什么数据不能出门
- 走 U 盘的那条路，最难被发现
- 在家办公，等于把办公室的边界搬到你家
- 外发之前问自己四句话

什么数据不能出门

敏感度与外发限制递增



公开

已对外发布，可自由外发。

内部

仅限在职员工，外发需业务负责人确认。

敏感

客户与员工个人信息、合同与报价；外发需安全与法务确认，并留痕。

重要数据

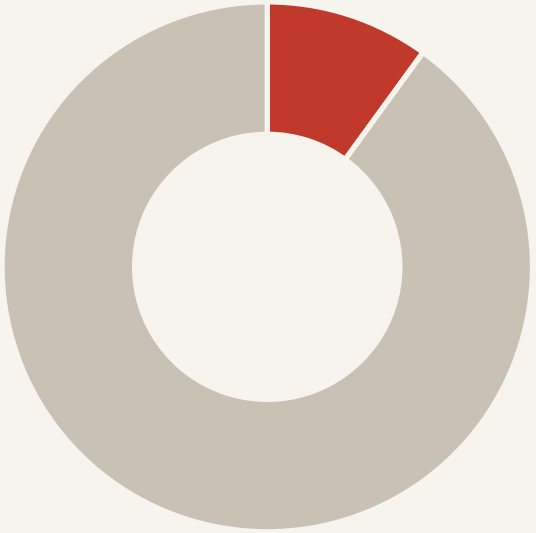
按主管部门目录认定；处理者须定期开展风险评估，并向主管部门报送报告。

法定依据：《网络安全法》第二十三条第（四）项数据分类、重要数据备份和加密；《数据安全法》第三十条重要数据定期风险评估并报送；《个人信息保护法》第五十一条分类管理与加密去标识化。

整理　四档名称与外发口径为本课依据上述法条所作的可执行归纳，以本企业制度为准。

来源：《网络安全法》（F006）、《数据安全法》（F024）、《个人信息保护法》（F030）

走 U 盘的那条路，最难被发现



最难被发现的一条路径

258 天

才被识别和遏制

与供应链入侵并列耗时最长（IBM 2026）

不是因为它更严重，而是因为它离开了所有能被监测到的通道。

不用私人 U 盘和移动硬盘转运公司数据；必须使用时，走公司审批与加密介质。

来源：IBM《数据泄露成本报告》2026（F065）

在家办公，等于把办公室的边界搬到你家

设备

公司数据只落在公司管控的终端上，个人电脑不做公司数据的落地存储。

网络

公共 Wi-Fi 下先连公司 VPN 再访问内部系统；不为「网速快」绕过管控通道。

账号

家人共用的电脑不保存公司账号口令；离开座位时锁屏。

屏幕与音频

视频会议共享屏幕前先关掉无关窗口；客户信息不出现在共享画面里。

> 《网络安全法》第二十三条要求留存相关的网络日志**不少于六个月**——在家的操作同样在日志里。

整理　四个场景为本课归纳的常见远程办公风险面

来源：《网络安全法》第二十三条（F005）

外发之前问自己四句话

一 **这是哪一档数据?**
分不清就按敏感处理。

二 **收件人有权知道吗?**
对外发送要有合同或授权依据。

三 **有没有更小的范围?**
能发摘要就不发全量，能去标识化就不发原始个人信息。

四 **留痕了吗?**
谁批的、什么时候发的、发了哪一版，要能查得到。

任何一句答不上来，就不要发。

四问依据《个人信息保护法》第五条至第七条的合法、正当、必要与影响最小原则操作化。

整理 四问为本课归纳的外发自查序列

来源：《个人信息保护法》第五条至第七条（F028）

下一章 · 合规红线 04

04

合规红线

这一章讲的是罚到个人的部分

- 先说一件事：条号全变了
- 三部法律落到你身上的，是这几条
- 罚款有上限，任职资格没有
- 同一份名单，员工的入罪门槛只要一半

先说一件事：条号全变了

用户行为红线	第十二条	**第十三条**
等级保护与日志留存六个月	第二十一条	**第二十三条**
应急预案与事件报告	第二十五条	**第二十七条**
禁止危害网络安全活动	第二十七条	**第二十九条**
个人信息收集使用原则	第四十一条	**第四十三条**
不得泄露与泄露补救告知	第四十二条	**第四十四条**
删除权与更正权	第四十三条	**第四十五条**
等保义务罚则	第五十九条	**第六十一条**
危害网络安全活动罚则	第六十三条	**第六十六条**
侵害个人信息罚则	第六十四条	**第七十一条（已改为转致）**

修正后第八十一条仍写「本法自 2017 年 6 月 1 日起施行」；
2026 年 1 月 1 日是修改决定的生效日；正确说法是「2025 年修正，修正后的规定自 2026 年 1 月 1 日起施行」。

来源：2025 年 10 月 28 日十四届全国人大常委会第十八次会议修改决定，修正后全文 81 条（F001、F002、F003）

三部法律落到你身上的，是这几条

《网络安全法》

2025 年修正

第十三条第二款

使用网络不得危害网络安全，不得利用网络从事危害国家安全、侵害他人名誉隐私知识产权等活动。

第二十九条

明知他人从事危害网络安全活动，仍提供技术支持、广告推广、支付结算等帮助的，同样违法。

帮朋友「跑个脚本」，同样违法。

《数据安全法》

2021 年 9 月 1 日施行

第三十二条

任何组织、个人收集数据应当采取合法、正当的方式，不得窃取或以其他非法方式获取数据。

第二十七条

企业须建立全流程数据安全管理制度，并组织开展数据安全教育培训。

这门课本身，就是这一条的落实。

《个人信息保护法》

2021 年 11 月 1 日施行

第十条

任何组织、个人不得非法收集、使用、加工、传输他人个人信息，不得非法买卖、提供或者公开。

第五十一条第（四）项

合理确定个人信息处理的操作权限，并定期对从业人员进行安全教育和培训。

个人信息的每一次经手，都在这两条里。

来源：《网络安全法》（F004、F008）；《数据安全法》（F025、F022）；《个人信息保护法》（F029、F030）

罚款有上限，任职资格没有

《网络安全法》第六十一条	单位 1 万–5 万元；拒不改正或致危害后果 5 万–50 万元；直接责任人员 1 万–10 万元	严重后果：单位 50 万–200 万元，个人 5 万–20 万元；特别严重：单位 200 万–1000 万元，个人 20 万–100 万元	第六十六条第三款：受治安管理处罚的五年内、受刑事处罚的终身，不得从事网络安全管理和网络运营关键岗位
《数据安全法》第四十五条	单位 5 万–50 万元；直接责任人员 1 万–10 万元	单位 50 万–200 万元；直接责任人员 5 万–20 万元	可责令停业整顿、吊销许可或营业执照
《个人信息保护法》第六十六条	拒不改正并处 100 万元以下；直接责任人员 1 万–10 万元	5000 万元以下或上一年度营业额 5% 以下；直接责任人员 10 万–100 万元	可禁止其在一定期限内担任董事、监事、高管和个人信息保护负责人

一次违规，**可能断送整条职业路径**——罚款有上限，任职资格没有。

来源：《网络安全法》（F014、F015、F017）、《数据安全法》（F026）、《个人信息保护法》（F032、F033）

同一份名单，员工的入罪门槛只要一半

≥ 50 条

行踪轨迹、通信内容、征信、财产信息

≥ 500 条

住宿、通信记录、健康生理、交易等信息

≥ 5000 条

其他公民个人信息

≥ 5000 元

违法所得

在履行职责或提供服务过程中获得的，上述数量或数额**减半**即达「情节严重」。

即 25 条 / 250 条 / 2500 条 / 违法所得 2500 元（依该规则折算）。

《刑法》第二百五十三条之一 侵犯公民个人信息罪；法释〔2017〕10 号，2017 年 6 月 1 日起施行。

监管处罚实例

滴滴案（2022 年 7 月 21 日，国家网信办）

处滴滴全球股份有限公司 80.26 亿元罚款，并对董事长兼 CEO 程维、总裁柳青各处 100 万元罚款。

监管处罚实例

知网案（2023 年 9 月 1 日，国家网信办）

责令停止违法处理个人信息并处 5000 万元罚款；手机知网等 14 款 App 存在违反必要原则收集、未经同意收集、未提供注销功能等行为。

下一章 · 应急与上报
05

来源：最高人民法院法释〔2017〕10 号（F039、F040）；国家互联网信息办公室（F041、F042）

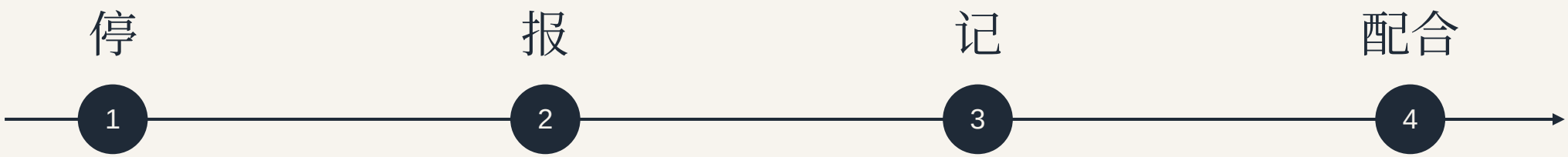
05

应急与上报

发现异常之后的几个小时，决定这件事的量级

- 发现异常后的四个动作
- 报给谁、多久、怎么报
- 及时上报是免责条款，不是追责起点

发现异常后的四个动作



停止操作；不关机、不重装、不删日志。第七条把「现场保护情况」列为必报内容。

立即通知本单位安全负责人；由单位按预案启动处置并向主管部门报告（网安法第二十七条）。

记下发现时间、现象、你做过的每一步操作（个保法第五十七条通知内容要求）。

配合调查与溯源；处置结束后 30 日内形成事件处置总结报告，按原渠道上报（第八条）。

研判属于**较大以上**网络安全事件的，一般网络运营者最迟**4 小时**内向属地省级网信部门报告。

整理　四个动作为本课依据上述法条与办法归纳的员工侧动作序列。

来源：《国家网络安全事件报告管理办法》（F077、F079、F080）；《网络安全法》（F007）；《个人信息保护法》（F031）

报给谁、多久、怎么报

涉及关键信息基础设施的网络运营者	保护工作部门、公安机关	最迟 1 小时
中央和国家机关各部门及其直属单位	本部门网信工作机构	最迟 2 小时
其他网络运营者（多数企业适用）	**属地省级网信部门**	**最迟 4 小时**

适用前提：按《网络安全事件分级指南》研判属于较大以上网络安全事件的才须报告。

网信部门已开通的六类报告渠道

12387 热线电话	12387 事件报告平台	微信「12387」 小程序	CNCERT 微信公众号	专用邮箱 12387@cert.org.cn	传真 010-82992387

涉嫌违法犯罪线索的，还应按规定向公安机关、国家安全机关报案（《网络数据安全管理条例》第十一条）。

来源：《国家网络安全事件报告管理办法》，网信办 2025 年 9 月 15 日发布、2025 年 11 月 1 日施行（F076、F077、F083）

及时上报是免责条款，不是追责起点

> 发生网络安全事件时，网络运营者已采取合理必要的防护措施、按照应急预案进行处置并有效降低影响危害、且按照本办法规定及时报告的，可视情从轻或不予追究相关单位和人员责任。
>
> ——《国家网络安全事件报告管理办法》第十一条

已采取合理必要防护措施

按预案处置并有效降低危害

按规定**及时报告**（三个条件须同时满足）

你越早说，公司越有可能落到「从轻或不予追究」这一侧；隐瞒只会把时间线拖到无法补救。

来源：《国家网络安全事件报告管理办法》第十一条，2025 年 11 月 1 日起施行（F081、F076）

随堂自测：五道判断题

答案与解析见讲者备注

1	数据泄露的根因中，IT 故障占比最高。	对	错
2	现行的权威口令标准要求每 90 天强制更换一次密码。	对	错
3	用私人 U 盘拷贝公司文件回家处理，只要不外传就没有风险。	对	错
4	违反《网络安全法》只会罚公司，不会罚到个人。	对	错
5	发现安全事件后先自己查清楚原因，查明白了再上报，比较稳妥。	对	错

整理　五道判断题为本课依据前述法条与统计自行设计，答案以页内引用来源为准。

对应章节：1 题第一章 · 2 题第二章 · 3 题第三章 · 4 题第四章 · 5 题第五章